

Endpoint Access Controls

CompTIA SecAI+: AI Security Certification Complete Exam Prep 2026 | Section 11: Security Controls for AI Systems

1. AI Endpoints as High-Value Attack Targets

An AI endpoint is a network-accessible interface—typically a REST API or WebSocket connection—through which clients interact with an AI system. For security AI systems, these endpoints are especially attractive targets. They may expose proprietary threat intelligence, trained model weights, sensitive investigation data, or expensive inference infrastructure. An unsecured AI endpoint offers attackers a triple prize: intelligence (what does your security AI know?), capability (how can your security AI be weaponised?), and resources (can your AI infrastructure be abused for free computation?).

The SecAI+ exam treats endpoint access controls as a foundational security layer—every AI deployment should implement them from day one, not as an afterthought. Expect questions that present scenarios with missing or misconfigured endpoint controls and ask you to identify the gap, the resulting risk, and the appropriate remediation.

2. Authentication vs Authorisation: Knowing the Difference

Concept	Question It Answers	Controls	Failure Risk
Authentication	Who are you?	API keys, OAuth 2.0, mTLS, SAML	Unauthorised identity gains access
Authorisation	What can you do?	RBAC, scopes, permissions, policies	Authenticated user exceeds their permitted actions
Audit	What did you do?	Logging, audit trails, SIEM integration	Actions cannot be attributed, investigated, or detected

Authentication and authorisation are complementary, not interchangeable. A system with strong authentication but weak authorisation allows any authenticated user to perform any action—a single compromised credential grants full access. A system with granular authorisation but weak authentication never verifies that the entity presenting credentials is who they claim to be. Both must be implemented correctly, and audit logging must record the decisions made by both systems.

3. API Key Management: Simple but Often Misconfigured

API keys are the most common authentication mechanism for programmatic AI endpoint access. Their simplicity is a double-edged sword: easy to implement correctly, but frequently misused. The most common API key security failures in practice are:

- Hardcoded keys in source code — keys embedded in application code are exposed to anyone with access to the repository. Secret scanning tools (GitLeaks, GitHub Advanced Security) detect and alert on this pattern.

- Keys stored in environment variables without encryption — environment variables are readable by any process with the same user context and are often logged by orchestration platforms.
- No key rotation policy — keys issued once and never rotated remain valid indefinitely, even if the original recipient's employment ends or their credentials are compromised.
- No scope restriction — keys that grant full API access when only read access is needed violate least privilege and maximise damage from compromise.
- No expiry — perpetual keys with no expiration date accumulate as forgotten credentials that create long-tail access risks.

API Key Lifecycle: Generate cryptographically random keys. Transmit only over TLS. Store in a secrets manager (HashiCorp Vault, AWS Secrets Manager). Rotate on a schedule (90 days is common). Scope to minimum required permissions. Revoke immediately on suspicion of compromise.

4. OAuth 2.0 for User-Delegated Access

OAuth 2.0 is the standard protocol for delegated authorisation—allowing a user to grant an application access to an AI endpoint on their behalf without sharing their password. The key security properties OAuth 2.0 provides for AI systems are:

- Token-based access — the application receives a time-limited access token, not the user's credentials. If the token is stolen, revocation invalidates it without requiring a password change.
- Scoped permissions — the token encodes the specific permissions granted. A token with scope 'threat:read' cannot write new indicators even if the user has write permissions.
- Short token lifetimes — access tokens typically expire in minutes to hours, limiting the window of opportunity for a stolen token.
- Refresh token separation — long-lived refresh tokens are stored server-side and are not transmitted with every API call, reducing exposure.

OAuth 2.0 is particularly valuable for AI systems accessed through user-facing interfaces (web portals, desktop applications) where users authenticate with their corporate identity provider. The AI endpoint never sees the user's password—it sees only the scoped, time-limited token issued by the IdP. This architecture also enables centralised session revocation: when an employee's account is disabled, their OAuth tokens become invalid immediately.

5. Mutual TLS: Certificate-Based Zero-Trust Authentication

Real-World Incident — Codecov Supply Chain Attack (Codecov, 2021): Attackers compromised a CI/CD tool and modified a script that was executed in thousands of customer environments. The script exfiltrated environment variables—including API credentials used to authenticate to downstream services. Because those services relied on API keys without mutual TLS, the exfiltrated keys were immediately usable. mTLS certificates, by contrast, are bound to a specific cryptographic identity and cannot be reused by an attacker who does not possess the private key.

Mutual TLS (mTLS) requires both the client and the server to present X.509 certificates, establishing cryptographic proof of identity on both sides of the connection. For inter-service communication in AI pipelines—where an orchestration service calls an AI model API, or where microservices exchange inference results—mTLS provides stronger authentication than API keys because the private key is never transmitted and cannot be copied by a credential-exfiltrating attack.

mTLS is most appropriate for: machine-to-machine communication between backend services; high-sensitivity AI endpoints handling classified or regulated data; and environments with compliance requirements mandating certificate-based authentication. The operational overhead (certificate issuance, rotation, revocation) is higher than API keys, which is why mTLS is typically reserved for high-value service-to-service authentication rather than general user access.

6. Role-Based Access Control for AI Endpoints

RBAC maps authenticated identities to sets of permitted actions. In the context of AI endpoints, roles should reflect operational need—the permissions required to perform a specific job function—not seniority or organisational hierarchy. A useful RBAC design for a security AI platform might include:

Role	Permitted Endpoints	Excluded Endpoints
Junior Analyst	Threat query (read), IoC lookup (read)	Threat attribution (read), Admin, Model management
Senior Analyst	All threat endpoints (read/write), Incident creation	Admin, Model management, Bulk export
SOC Manager	All analyst endpoints, Reporting (read/write)	Model management, System configuration
Platform Admin	All endpoints including management and configuration	N/A — full access
External Partner	Threat feed submission (write), Feed status (read)	All internal endpoints
Analytics Service	Threat data (read only, scoped to anonymised indicators)	All write, admin, and management endpoints

The principle of least privilege drives RBAC design: each role receives the minimum access needed to perform its function. Roles should be reviewed periodically—quarterly for external partners, annually for internal roles—and access should be removed when the business need ends.

7. Network-Layer Controls: IP Allow-listing and Segmentation

Network-layer controls provide a defence-in-depth layer that operates independently of application-layer authentication. Even if an attacker obtains valid API credentials, network controls can prevent them from using those credentials unless they are connecting from an approved network location.

- IP allow-listing — restrict endpoint access to known source IP ranges (partner networks, corporate VPN exit nodes, specific data centres). Effective for machine-to-machine integrations with fixed source addresses; impractical for human users who may work from variable locations.

- Network segmentation — deploy internal AI endpoints in network segments that are not reachable from the internet. An attacker who discovers the endpoint's URL cannot reach it if it is in a private VLAN with no public routing.
- DMZ placement for external endpoints — endpoints that must be internet-accessible should sit in a DMZ with strict firewall rules limiting inbound traffic to known ports and protocols and blocking all outbound connections except to specific internal services.
- Geo-blocking — blocking access from geographic regions where the organisation has no legitimate user base reduces automated attack noise and limits the usability of stolen credentials for attackers in those regions.

8. Request Signing: Preventing Replay and Tampering

For the highest-security AI endpoints—particularly those involved in threat intelligence sharing with external partners—request signing provides cryptographic assurance that: (1) the request was created by the stated sender, (2) the request content has not been modified in transit, and (3) the request is not a replay of a previously captured legitimate request.

AWS Signature Version 4 is the most widely used request signing scheme and is a useful reference model. The signer includes a timestamp and a content hash in the signed portion of the request. The server rejects requests with timestamps outside a narrow window (typically ± 5 minutes), preventing replay attacks. Content hashing ensures that a man-in-the-middle cannot modify the request body without invalidating the signature.

Request signing is distinct from transport encryption (TLS): TLS protects data in transit from eavesdropping, but once the TLS session is terminated at the server, TLS provides no assurance about who sent the request. Request signing provides that assurance at the application layer, which is why the two controls are complementary rather than redundant.

9. Logging, Audit Trails, and the Security Value of Endpoint Telemetry

Endpoint access logs are a primary source of security telemetry for AI systems. Unlike application logs that record what the AI system did, endpoint access logs record who accessed it, from where, when, and what they asked for. This distinction matters: application logs tell you about the AI's behaviour; endpoint logs tell you about the humans and services interacting with the AI.

Minimum fields for a useful AI endpoint access log:

- Timestamp (UTC, millisecond precision) — for correlation with other event sources.
- Authenticated identity (user ID or service account, not just IP) — for attribution.
- Source IP address and, where available, user agent — for geolocation and device type analysis.
- Requested endpoint and HTTP method — what was asked for.
- Response code and latency — for anomaly detection (sudden latency increases may indicate resource exhaustion attacks).
- Data volume returned — for data exfiltration detection (unusually large responses may indicate scraping).
- Authorisation outcome — was the request permitted, denied, or partially fulfilled?

These logs should be shipped to a SIEM in near-real-time and retained for a minimum period aligned with the organisation's compliance requirements (commonly 12 months for regulated industries). Access to the logs themselves must be controlled—logs that capture AI query content may include sensitive investigation details.

10. Monitoring Patterns: Detecting Credential Compromise Through Endpoint Telemetry

Endpoint logs are most valuable when baseline behaviour has been established and deviations trigger alerts. Anomaly signals that indicate potential credential compromise or abuse:

- Access from a new geographic location — API key used from a country not previously seen for that credential.
- Off-hours access for accounts with predictable schedules — analyst credentials active at 03:00 when the analyst always works 08:00–18:00.
- Rapid authentication failures followed by success — password spray or key guessing attack that succeeded on the nth attempt.
- Sudden volume spike — account that normally makes 50 requests per day making 5,000 in an hour.
- Large response volumes — requests that return significantly more data than the account's typical responses (scraping or exfiltration pattern).
- Access to endpoints outside the account's normal pattern — an analytics service account suddenly querying the user management endpoint.

Key Terms Glossary

Term	Definition
AI endpoint	A network-accessible interface (API or WebSocket) through which clients interact with an AI system.
Authentication	The verification of claimed identity before granting access; answers 'who are you?'
Authorisation	The enforcement of permitted actions for an authenticated identity; answers 'what can you do?'
API key	A shared secret token used as a credential for programmatic API authentication; must be generated randomly, rotated regularly, and scoped to minimum permissions.
OAuth 2.0	A delegated authorisation protocol that allows users to grant applications scoped, time-limited access to resources without sharing passwords.
Mutual TLS (mTLS)	A TLS authentication mode in which both the client and server present X.509 certificates, providing cryptographic proof of identity on both sides of the connection.
Role-Based Access Control (RBAC)	An authorisation model in which permissions are assigned to roles, and roles are assigned to users, enforcing the principle of least privilege.
IP allow-listing	A network control that restricts endpoint access to a defined set of approved source IP addresses or ranges.

Request signing	A cryptographic mechanism that proves the origin and integrity of an API request, preventing tampering and replay attacks.
Audit trail	A time-stamped, tamper-evident record of endpoint access events including identity, action, data accessed, and outcome.

Quick Revision Checklist

- AI endpoints for security systems are high-value targets offering intelligence, capability, and resource abuse opportunities.
- Authentication (who are you?) and authorisation (what can you do?) are distinct—both must be implemented correctly.
- API keys must be cryptographically random, TLS-transmitted, secrets-manager-stored, rotation-scheduled, scoped to least privilege, and revocable.
- OAuth 2.0 provides user-delegated, scoped, time-limited access without exposing user credentials to the AI endpoint.
- Mutual TLS provides the strongest authentication for inter-service communication by requiring certificate-based identity on both client and server.
- RBAC assigns permissions based on job function, not seniority; each role receives minimum required access.
- IP allow-listing adds a network-layer defence that remains effective even if application-layer credentials are compromised.
- Network segmentation prevents internet access to internal AI endpoints regardless of credential exposure.
- Request signing provides cryptographic proof of request origin and integrity, preventing man-in-the-middle tampering and replay attacks.
- Endpoint access logs must capture identity, source IP, endpoint, method, response code, latency, and data volume for security telemetry.
- Anomaly signals—new geographic access, off-hours activity, volume spikes—indicate potential credential compromise and should trigger investigation.

10 Exam-Based MCQs — Endpoint Access Controls

Test yourself after reading. These questions are written in real exam style — scenario-heavy, with plausible distractors. Read every explanation, including for questions you answered correctly.

Q1. *Scenario:* An API key with full read/write access to an AI threat intelligence platform was leaked to a public GitHub repository six months ago. A financial services firm's security team discovers that an API key used to authenticate to their AI threat intelligence platform has been leaked in a public GitHub repository. The key was committed by a developer six months ago. The key grants full read and write access to all platform endpoints. Which immediate actions are MOST appropriate?

- A) Rotate the API key and notify the developer to be more careful in the future.
- B) Revoke the API key immediately, audit all access logs for the past six months using the compromised key, and issue a new key scoped to minimum required permissions.

- C) Delete the GitHub repository and rotate the API key.
- D) Issue a new API key and run a code scan on the repository to find other exposed keys.

Answer: B **Explanation:** B is correct because the immediate priority is revoking the compromised credential to stop ongoing abuse. However, six months of potential exposure means a thorough audit of what was accessed, modified, or exfiltrated using the key is equally critical. Issuing the new key with least-privilege scoping prevents a recurrence. A is wrong because rotation alone is insufficient—it does not address what may have happened during six months of exposure. C is wrong because deleting the repository does not invalidate the key and does not address the historical exposure; the key may have been copied by any number of parties before deletion. D is wrong because code scanning and key replacement are important follow-up actions but must come after immediate revocation and log investigation.

Q2. Scenario: A SOC is deploying an AI incident response assistant with three user populations: junior analysts, senior analysts, and SOC managers, each requiring different permission levels. A security operations centre deploys an AI-powered incident response assistant. Junior analysts require access to query the AI for threat context. Senior analysts also need the ability to create and update incident records. SOC managers need access to all analyst functions plus reporting. Which access control design BEST implements least privilege?

- A) Grant all authenticated SOC users full access to simplify administration.
- B) Implement RBAC with three roles: Junior Analyst (query only), Senior Analyst (query and write incidents), and SOC Manager (all analyst permissions plus reporting).
- C) Require all analysts to share a single SOC service account with shared credentials.
- D) Implement IP allow-listing to restrict access to users connecting from the SOC network.

Answer: B **Explanation:** B is correct because RBAC with differentiated roles ensures each user has exactly the permissions required for their function and no more. This limits the blast radius of any credential compromise—a junior analyst account cannot create records, and a senior analyst account cannot access reporting. A is wrong because full access for all users eliminates least privilege; a junior analyst credential compromise would grant full platform access. C is wrong because shared credentials eliminate individual accountability and make audit trails meaningless—you cannot determine which analyst performed which action. D is wrong because IP allow-listing is a valuable additional layer but does not implement least privilege at the action level—any user on the SOC network could still perform any action.

Q3. Scenario: An AI malware analysis service detects a research firm's API key making 8,000 requests in one hour (typical: 200/day) with large indicator data responses. An AI-powered malware analysis service processes submissions from multiple external security research firms via a REST API. The security team observes that a research firm's API key is being used to make 8,000 requests in a single hour, compared to their typical 200 requests per day. The requests are returning large volumes of indicator data. Which scenario is MOST likely and what is the BEST response?

- A) The firm is running an automated analysis pipeline; increase their rate limit to accommodate the load.
- B) The API key may have been compromised and is being used to scrape indicator data; suspend the key pending investigation and contact the firm out-of-band.

- C) The firm has a legitimate surge in malware samples; approve the temporary quota exception.
- D) The request volume indicates a billing dispute; escalate to the accounts team.

Answer: B **Explanation:** B is correct because the combination of a sudden 40x volume spike and large response payloads matches the pattern of credential compromise followed by data scraping. Contacting the firm out-of-band (phone or alternative email, not through the platform) verifies whether the activity is authorised without tipping off an attacker who may be monitoring the compromised account. Key suspension during investigation contains the damage. A is wrong because accommodating the load without investigating treats a high-confidence anomaly as a routine operations request. C is wrong because the 40x spike with large data volumes is not consistent with a simple sample surge—the pattern is specifically indicative of scraping. D is wrong because request volume is not a billing metric and does not indicate a billing dispute.

Q4. Which of the following BEST describes why mutual TLS (mTLS) provides stronger authentication than API keys for inter-service communication in an AI pipeline?

- A) mTLS keys are longer than API keys and therefore harder to brute-force.
- B) mTLS requires both client and server to present certificates, and the private key is never transmitted, so a credential-exfiltrating attack cannot yield a usable credential.
- C) mTLS is encrypted, while API key transmission over HTTPS is not.
- D) mTLS automatically rotates certificates every 90 days, eliminating the rotation burden.

Answer: B **Explanation:** B is correct because the critical security property of mTLS is that authentication is based on possession of a private key, which is used to sign a challenge but is never transmitted. An attacker who intercepts network traffic or exfiltrates environment variables cannot obtain the private key through these vectors. API keys, by contrast, are secrets that must be transmitted with each request and can be exfiltrated directly. A is wrong because key length is not the primary distinction between mTLS and API keys. C is wrong because API keys transmitted over HTTPS are encrypted in transit—this is not a meaningful distinction. D is wrong because mTLS certificates do not rotate automatically; certificate lifecycle management is an operational overhead of mTLS, not an advantage.

Q5. A security architect is designing network controls for a new AI threat hunting platform. The platform includes an internal AI inference engine that should only be accessible to the SOC VLAN, and a partner API that must be internet-accessible. Which network design BEST meets these requirements?

- A) Deploy both components in the DMZ with firewall rules restricting the inference engine to SOC IP ranges.
- B) Deploy the inference engine in the private SOC VLAN with no internet routing, and deploy the partner API in the DMZ with inbound firewall rules restricting access to partner IP ranges.
- C) Deploy both components on the public internet and use API key authentication to control access.
- D) Deploy the inference engine in the cloud and the partner API on-premises.

Answer: B **Explanation:** B is correct because the inference engine has no business requirement for internet exposure and should be in a private VLAN with no public routing—network segmentation ensures it cannot be reached even if credentials are compromised. The partner API must be internet-accessible and therefore sits in the DMZ, where firewall rules limit inbound connections to known partner IP ranges,

adding a network-layer defence over the API authentication. A is wrong because placing the inference engine in the DMZ still exposes it to internet-reachable networks; firewall rules reduce but do not eliminate this exposure. C is wrong because public internet deployment for internal components is unjustifiable when private network options exist. D is wrong because cloud/on-premises placement is not relevant to network segmentation requirements.

Q6. An organisation's AI security platform access logs show that a senior analyst's credentials were used to access the platform from Singapore at 02:00 local time. The analyst is based in London and has never previously accessed the platform from outside the UK. Which response is MOST appropriate?

- A) Block all access from Singapore IP addresses at the firewall.
- B) Log the event and investigate during normal business hours.
- C) Suspend the analyst's credentials immediately and contact the analyst through a separate channel to verify the access.
- D) Increase the analyst's session timeout to ensure legitimate remote sessions are not interrupted.

Answer: C **Explanation:** C is correct because the combination of an anomalous geographic location and off-hours access is a high-confidence indicator of credential compromise. Credential suspension prevents ongoing damage while the out-of-band verification establishes whether the access was legitimate (e.g. the analyst is travelling and forgot to notify IT) or malicious. B is wrong because waiting until business hours allows a potential attacker to continue accessing the platform for hours. A is wrong because geo-blocking all Singapore IPs is a blunt control that would affect other legitimate users connecting from that region. D is wrong because session timeout adjustment is irrelevant to the anomaly and does not address the potential compromise.

Q7. What is the PRIMARY security purpose of implementing request signing on a threat intelligence sharing API?

- A) To encrypt the request body so that eavesdroppers cannot read the threat intelligence being submitted.
- B) To provide cryptographic proof that the request was not modified in transit and was created by the stated sender.
- C) To replace the need for TLS encryption on the API endpoint.
- D) To generate API keys automatically for new partners who onboard to the platform.

Answer: B **Explanation:** B is correct because request signing provides two distinct assurances: authenticity (the request came from the entity with possession of the signing key) and integrity (the request body has not been altered between signing and receipt). These properties are not provided by TLS alone. A is wrong because request signing does not encrypt content—that is the role of TLS. C is wrong because request signing complements TLS, not replaces it; TLS provides transport confidentiality while request signing provides application-layer integrity and authenticity. D is wrong because request signing has no relationship to API key generation.

Q8. An organisation wants to implement OAuth 2.0 for its AI security platform to allow analysts to authenticate with their corporate SSO credentials. Which statement BEST describes the security benefit of this approach compared to platform-specific passwords?

- A) OAuth 2.0 eliminates the need for any authentication because analysts have already logged in to their corporate accounts.
- B) OAuth 2.0 scoped tokens expire automatically and can be centrally revoked without requiring a password change on the AI platform.
- C) OAuth 2.0 provides stronger encryption for API calls than password-based authentication.
- D) OAuth 2.0 prevents analysts from sharing their credentials with colleagues.

Answer: B **Explanation:** B is correct because the security advantages of OAuth 2.0 for this use case are token expiration (limiting the useful lifetime of any stolen token) and central revocation (disabling the user's corporate SSO account immediately invalidates their AI platform access without a separate platform password reset). This is particularly important for offboarding—a leaving employee's access to all OAuth-integrated systems is revoked simultaneously when their IdP account is disabled. A is wrong because OAuth 2.0 is a delegated authorisation protocol, not a bypass of authentication—the corporate SSO login is the authentication step. C is wrong because OAuth 2.0 does not affect transport encryption, which is handled by TLS independently. D is wrong because credential sharing is an organisational policy problem that OAuth 2.0 does not technically prevent.

Q9. Which minimum set of fields should be captured in an AI endpoint access log to support both security investigation and anomaly detection?

- A) Timestamp, endpoint URL, and HTTP response code only.
- B) Authenticated user identity, source IP, timestamp, endpoint, HTTP method, response code, and data volume returned.
- C) Source IP address and timestamp only, to minimise the personal data retained in logs.
- D) Full request and response body for every API call, to ensure complete forensic coverage.

Answer: B **Explanation:** B is correct because this set of fields supports attribution (authenticated identity), geolocation analysis (source IP), temporal correlation (timestamp), action identification (endpoint and method), outcome determination (response code), and exfiltration detection (data volume). Together these fields enable both investigation and behavioural anomaly detection. A is wrong because without identity and source IP, logs cannot support attribution or geolocation-based anomaly detection. C is wrong because source IP alone is insufficient for identity attribution; without authenticated user ID, logs cannot link actions to individuals. D is wrong because full request/response body logging at scale is prohibitively expensive, creates significant data retention compliance risks (query bodies may contain sensitive investigation content), and is not necessary for the core security telemetry use cases.

Q10. An AI security platform issues API keys to three categories of client: internal services, security partner organisations, and individual analyst accounts. Which key management policy BEST implements differentiated least privilege across these categories?

- A) Use a single master API key for internal services and separate keys for partners and analysts.

- B) Issue individual keys per client with scopes limited to required endpoints, with 90-day rotation for partners and analysts and shorter rotation for internal services given their automated access.
- C) Issue keys with identical scopes for all clients and rely on RBAC enforced at the application layer for differentiation.
- D) Issue one key per organisation rather than per service or user, to reduce administrative overhead.

Answer: B **Explanation:** B is correct because per-client keys with endpoint-specific scopes enforce least privilege at the key level—a partner key that can only submit threat indicators cannot query internal investigation data even if stolen. Differentiated rotation schedules reflect risk profiles: internal services are automated and may have more frequent key usage with tighter monitoring, warranting shorter rotation cycles. Partners and external clients warrant regular rotation to manage long-term credential exposure. A is wrong because a single master key for all internal services means any compromised internal service has access equivalent to all others—least privilege is violated. C is wrong because identical scopes eliminate the key-level least privilege layer, leaving only application-layer RBAC as the sole control. D is wrong because per-organisation keys mean all services and users within an organisation share a credential—a compromise of one account exposes all others in the organisation.